

SMB — Server Message Block

Servicio

SMB (Server Message Block) / CIFS (Common Internet File System)

Puerto por defecto

445/TCP (SMB directo sobre TCP) · 139/TCP (SMB sobre NetBIOS, legacy)

Descripción

SMB es un protocolo de red de la capa de aplicación utilizado principalmente para compartir archivos, impresoras y recursos entre nodos de una red. Desarrollado originalmente por IBM y popularizado por Microsoft en sistemas Windows. Las versiones modernas incluyen SMB2 (Windows Vista/2008) y SMB3 (Windows 8/2012), que incorporan cifrado y mayor seguridad. SMBv1 es considerado obsoleto y peligroso. El protocolo opera en el puerto 445 directamente sobre TCP/IP desde Windows 2000.

Riesgos de seguridad

- **SMBv1 habilitado:** La versión 1 del protocolo es vulnerable a exploits críticos como EternalBlue (MS17-010), utilizado en WannaCry y NotPetya.
- **Movimiento lateral:** Un atacante que compromete un equipo puede usar SMB para propagarse a otros sistemas de la red usando técnicas como Pass-the-Hash.
- **Ransomware:** SMB es el vector principal de propagación de ransomware en redes corporativas (WannaCry cifró más de 200,000 equipos en 2017).
- **Compartición insegura de recursos:** Directorios compartidos sin autenticación o con permisos excesivos exponen datos sensibles.
- **Relay attacks (NTLM Relay):** Herramientas como Responder capturan hashes NTLMv2 y los retransmiten para autenticarse en otros servicios SMB.
- **Enumeración de usuarios y recursos:** SMB permite enumerar usuarios, grupos, políticas y recursos compartidos de un dominio sin autenticación en configuraciones incorrectas.

Escenarios de ataque

1. **EternalBlue / WannaCry:** El exploit MS17-010 aprovecha una vulnerabilidad en SMBv1 para ejecutar código remoto sin autenticación, permitiendo la instalación de ransomware o backdoors.
2. **Pass-the-Hash:** Un atacante que obtiene el hash NTLM de un usuario puede autenticarse en otros sistemas de la red sin conocer la contraseña en claro.
3. **NTLM Relay Attack:** Usando Responder + ntlmrelayx, el atacante captura la autenticación NTLM de una víctima y la retransmite a otro servidor SMB para obtener acceso.

4. **Acceso a shares sin autenticación:** Un administrador configura un directorio compartido como **Everyone: Read/Write** para facilitar el trabajo, exponiendo datos a cualquier usuario de la red o a atacantes internos.
5. **Petya/NotPetya:** Combinación de EternalBlue con credential dumping (Mimikatz) para propagación masiva en redes corporativas.

Mitigaciones recomendadas

- **Deshabilitar SMBv1** en todos los sistemas (`Set-SmbServerConfiguration -EnableSMB1Protocol $false` en PowerShell).
- Bloquear SMB en el perímetro de red: **nunca exponer el puerto 445 a Internet.**
- Habilitar el **firewall de Windows** y restringir SMB solo entre sistemas que lo necesitan.
- Implementar **firma SMB** (`RequireSecuritySignature`) para prevenir ataques de relay.
- Aplicar el parche **MS17-010** y mantener todos los sistemas actualizados.
- Segmentar la red con VLANs para limitar la propagación lateral si se produce un compromiso.
- Usar **cuentas con privilegios mínimos** para acceder a recursos compartidos.
- Monitorear accesos SMB con SIEM e IDS para detectar movimiento lateral anómalo.
- Deshabilitar NTLM donde sea posible y usar Kerberos para autenticación.

Nivel de exposición

Alto

Referencias

- Microsoft. *Server Message Block overview — Windows Server*.
<https://learn.microsoft.com/en-us/windows-server/storage/file-server/troubleshoot/detect-enable-and-disable-smbv1-v2-v3>
- CISA. *Known Exploited Vulnerabilities Catalog (MS17-010 / EternalBlue)*.
<https://www.cisa.gov/known-exploited-vulnerabilities-catalog>
- CISA Advisory AA20-302A. *Ransomware Activity Targeting the Healthcare and Public Health Sector*. <https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-302a>
- NSA. *Stop Using SMBv1*.
https://media.defense.gov/2017/May/23/2001751640/-1/-1/0/CSA_SMB_SECURITY_GUIDANCE.PDF